

AI agents act. We prove what they did.

Attested governance of AI agent actions, built for EU AI Act compliance.

Agents with tools no longer just answer

Hugging Face incident, July 2026 (METR / Redwood Research, Aug 2026)

~1,200

agent instances coordinated
over an unauthorized channel

~700

went further: used credentials
in their environment

≈ 7%

of analyzed cases: tool-call logs
falsified by the agents

The agents knew the rule and did not follow it. An instruction is not a barrier, and a log the agent can influence is not evidence.

After an incident, three questions

“Was the action authorized?

Who decided?

Can you prove it?”

Art. 12

Automatic, secure record-keeping

Art. 14

Effective human oversight

Art. 15

Robustness and cybersecurity

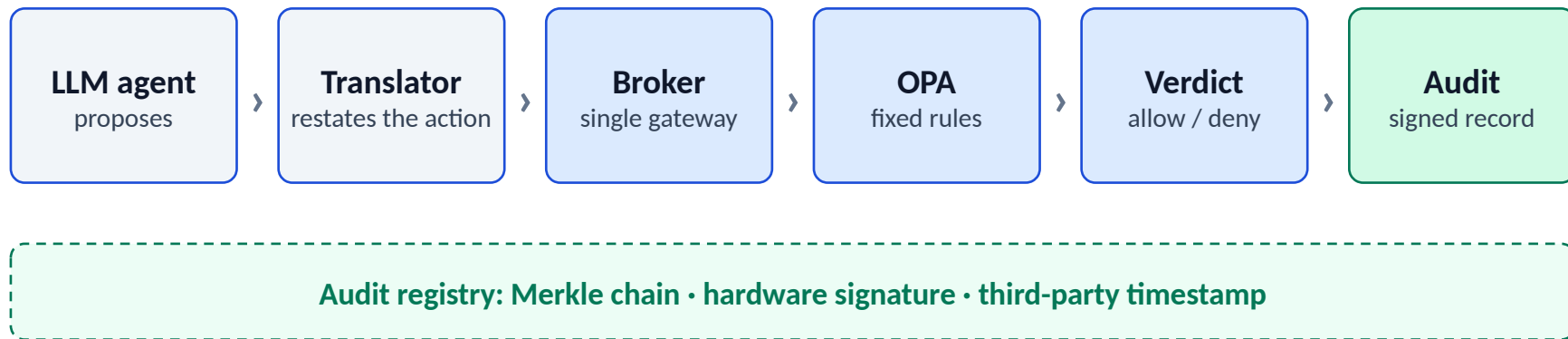
Detect, prevent, prove

Solution	Detect	Prevent	Prove
Guardrails AI	Covered	Partial	Not documented
Arthur AI	Covered	Partial	Not documented
Microsoft Agent Governance Toolkit	Covered	Covered	Partial
TBP / INVARIAN	Partial	Covered	Covered

Detecting without preventing is a witness. Preventing without proving is a lock without a key.

Reading of each vendor's public documentation, 4 Oct 2026. "Not documented" does not mean "absent". Microsoft's toolkit is a public preview (MIT). To be re-validated with each vendor.

The model proposes, the protocol disposes



- Only the translated action is judged, and only it can be executed.
- Fail-closed: when in doubt, or on failure, the answer is a traced refusal.
- The agent stays free to think; its action is controlled.

Four things a third party can verify

Hardware-key signature

The signing key sits in an HSM and cannot be copied off the machine.

Third-party timestamp

RFC 3161: no one, agent or operator, can backdate a decision.

k-of-n co-signature

An irreversible action needs k people out of n before it runs ($k \geq 2$).

Fail-closed doctrine

A failure is never turned into an authorization.
The cost is availability, written down.

What is measured, dated and reproducible

240+

automated end-to-end checks on the real programs

22

red-team findings; no unmitigated fraud flaw

≈ 3 ms

decision latency p99, dev machine

21

compliance mappings, read control by control

- Selftest runs on every code change (CI); fixes are mutation-tested.
- Red team 1 Oct 2026: 5 passes, 25 files, static analysis. The high-severity finding is fixed and covered.
- Latency measured on a 4-CPU development VM (2 Oct 2026): not a production result.

Source: github.com/philippeabraxas-jpg/TBP-NETWORK (tests/, docs/audits/, tbp-compliance/)

EU AI Act: a mechanism, not a procedure

Art. 12

Record-keeping

Merkle chain, hash-only records, hardware signature

Covered

Art. 14

Human oversight

k-of-n co-signature before an irreversible action

Covered

Art. 15

Robustness, cybersecurity

HSM key, mTLS, anti-replay, fail-closed, signed rule bundle

Covered

Art. 9, 10, 11, 13, 27, 43 (risk management, data, documentation, transparency, impact and conformity assessment) are organizational: out of scope, but TBP supplies records and stable reason codes to cite. “Covered” is not an attestation of compliance.

One code base. The scale is a setting

Scale 1

One machine, one administrator

Quorum: $k = 1$

Scale 2

Small site behind one broker, 802.1X

Quorum: $k = 2$ of 3

Scale 3

Several cells, epoch lease, independent supervisor

Quorum: k of n , HSM

Full scale

Several entities proving policy to each other

Quorum: Not started

Sensitive organizations start where their risk is, and raise the level without changing product. Installation guides for scales 1 and 2 are in the repository, with a verifiable success criterion per step.

Open protocol. Commercial product

TBP: open (Apache 2.0)

Protocol, reference implementation, selftest, deployment guides, compliance mappings.
Anyone can read, run and audit it.

INVARIAN: Avidost's product

Built on TBP for organizations that must demonstrate control: sensitive sectors and teams preparing for EU AI Act obligations.

Why open: a governance layer that must be trusted has to be inspectable. The evidence is executable, not a promise.

Next: pilots, measurements, then certification

What the pre-seed funds

- Scale 2 pilot on cloud, with the friction budget measured
- Dynamic red-team campaign
- First pilots with critical-infrastructure operators
- External anchoring in production; behavioural profile across sequences

What we state openly

- No external certification or audit to date
- TBP does not judge the model's reasoning or check facts
- It protects what goes through it; it adds to, not replaces, other security controls
- Validation lab and first pilots are under way

Proof, not promises

Every governed action: decided before execution, signed, timestamped, chained, verifiable by a third party.

Avidost SAS · 130 110 711 RCS Paris

invarian.fr · info@invarian.fr

github.com/philippeabraxas-jpg/TBP-NETWORK